

# Actividad 1. Análisis y planificación del Pentest

*Análisis y planificación de la evaluación de seguridad para Aurora Market*

Preparado para: Aurora Market  
Preparado por: Jennifer Marlet  
Reveles Gurrola

Fecha: septiembre 2026

**Clasificación: CONFIDENCIAL**  
**Hacker Women Council | Ethical Hacking**

# Contenidos

1. Objetivos del Pentest
2. Alcance
3. Autorización y condiciones
4. Tipo del pentest
5. Planificación
6. Fases del pentest
7. Investigación

# 1. Objetivos del Pentest

**Objetivo 1:** Identificar vulnerabilidades de la aplicación web.

Evaluar la aplicación web de Aurora Market para identificar vulnerabilidades relacionadas con autenticación, autorización, gestión de sesiones, validación de entradas, configuración y manejo de información. Esto permitirá que el equipo de Aurora Market conozca las debilidades técnicas que podrían ser aprovechadas por un atacante.

**Objetivo 2:** Evaluar el impacto de las vulnerabilidades.

Determinar qué consecuencias tendría la explotación de las vulnerabilidades encontradas, especialmente sobre la confidencialidad, integridad y disponibilidad de la información de los clientes y de la empresa. Esto permitirá a Aurora Market priorizar las vulnerabilidades según el riesgo que representen para el negocio.

**Objetivo 3:** Evaluar los controles de acceso entre usuarios.

Comprobar si los diferentes tipos de usuarios pueden acceder únicamente a las funciones e información que les corresponden. Esto permitirá determinar si existe un problema de autorización o control de acceso que pueda permitir el acceso indebido a información de otros clientes.

## 2. Alcance

**Sí se evaluará:**

- Aplicación web de Aurora Market.
- Funcionalidades de registro e inicio de sesión.
- Recuperación/cambio de contraseña, si existe.
- Gestión de sesiones.
- Diferentes roles y tipos de usuarios.
- Área de clientes y administrativa, utilizando cuentas de prueba autorizadas.
- Funciones relacionadas con productos.
- Funciones relacionadas con pedidos.
- Manejo de información de usuarios.
- Mecanismos de autorización y control de acceso.

**No se evaluará:**

- Redes sociales de Aurora Market.
- Cuentas de correo de empleados.
- Equipos personales o corporativos de empleados.
- Sistemas de proveedores externos.
- Infraestructura que no pertenezca directamente a la aplicación autorizada.
- Ataques contra terceros.
- Ingeniería social.
- Denegación de servicio (DoS/DDoS).
- Eliminación o modificación de información real.
- Acciones que puedan interrumpir deliberadamente el servicio.
- Acceso no autorizado a información real de clientes.

## 3. Autorización y condiciones

**Permisos requeridos:**

- Autorización formal y por escrito para realizar el pentest.
- Dominios o URL exactos que forman parte del alcance.
- Cuentas de prueba para los diferentes roles de usuario.
- Persona de contacto responsable durante las pruebas.
- Ventana de tiempo autorizada para realizar las pruebas.
- Confirmación de sistemas que pueden y no pueden ser evaluados.

- Autorización específica para pruebas de vulnerabilidades potencialmente sensibles.
- Información de contacto para reportar inmediatamente un incidente crítico.

#### Condiciones acordadas:

- Realizar las pruebas preferentemente durante horarios de menor actividad.
- No realizar pruebas destructivas.
- No ejecutar DoS/DDoS.
- No eliminar ni modificar deliberadamente información real.
- Utilizar cuentas y datos de prueba siempre que sea posible.
- Detener una prueba si existe riesgo de afectar la disponibilidad de la plataforma.
- Documentar todas las pruebas realizadas.
- Registrar fecha, hora, prueba, resultado y evidencia.
- Informar inmediatamente cualquier vulnerabilidad crítica.
- Mantener confidencial la información obtenida durante la evaluación.

## 4. Tipo del pentest

Tipo de pentest elegido: Gray Box

Justificación: Considerando que el equipo contará con información parcial y accesos autorizados a la aplicación, pero no dispondrá inicialmente de conocimiento completo sobre su arquitectura, código fuente o infraestructura se ha definido un enfoque Gray Box. Esto permite evaluar tanto las vulnerabilidades visibles para un atacante como determinados controles internos mediante cuentas de prueba.

## 5. Planificación

| Elemento                           | Planificación                                                                                                                                                                                                                            |
|------------------------------------|------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------|
| Objetivos                          | Identificar vulnerabilidades, evaluar su impacto y comprobar los controles de acceso entre usuarios                                                                                                                                      |
| Alcance                            | Aplicación web y funcionalidades directamente relacionadas, excluyendo sistemas, cuentas y terceros no autorizados.                                                                                                                      |
| Permisos y condiciones             | Autorización escrita, cuentas de prueba, horarios definidos, contacto de emergencia y prohibición de pruebas destructivas.                                                                                                               |
| Metodología a utilizar             | OWASP                                                                                                                                                                                                                                    |
| Recopilación de información previa | Investigación en motores de búsqueda, examen del sitio web, análisis de DNS, así como fingerprinting de servicios (limitado a lo observable desde la aplicación web) y escaneo de vulnerabilidades de forma controlada y no destructiva. |
| Recursos necesarios                | Equipo de pruebas, navegador, proxy de análisis HTTP, herramientas de enumeración y análisis de seguridad, sistema para documentar evidencias y cuentas de prueba.                                                                       |
| Programación del pentest           | Reconocimiento, análisis de vulnerabilidades, explotación controlada, post explotación limitada, análisis de resultados, informe.                                                                                                        |

## 6. Fases del pentest

- **Reconocimiento:** Examinar la aplicación, identificar funcionalidades, tecnologías, usuarios, endpoints y mecanismos de autenticación y gestión de sesiones. Se utilizará información pública y técnicas activas únicamente sobre los elementos autorizados.  
*Duración: 1 día.*
- **Análisis de vulnerabilidades:** Evaluar autenticación, autorización, sesiones, entradas,

configuración, tecnologías detectadas y permisos de los diferentes usuarios. Los puertos y la infraestructura no serán evaluados al no estar incluidos en el alcance. Como complemento, se realizará un modelado de amenazas, identificando los activos de la aplicación, las amenazas asociadas y su posible impacto. Posteriormente, se evaluará el riesgo y se propondrán contramedidas, considerando principalmente la confidencialidad, integridad y disponibilidad de la información. *Duración: 1.5 días.*

- **Explotación:** Seleccionar y ejecutar pruebas controladas para confirmar vulnerabilidades y determinar su impacto, utilizando cuentas y datos de prueba. *Duración: 1 día.*
- **Post-explotación:** Determinar qué información y privilegios podrían obtenerse tras una explotación. No se realizará persistencia, eliminación de rastros, exploración de red ni ataques a otros sistemas. *Duración: 0.5 días.*
- **Informe:** Documentar hallazgos, evidencias, impacto, nivel de riesgo y recomendaciones de mitigación. *Duración: 1 día.*

## 7. Investigación

### Metodología elegida:

OWASP WSTG

### ¿Por qué sería útil para este proyecto?

Se selecciona OWASP Web Security Testing Guide (WSTG) debido a que el objetivo principal del proyecto es evaluar una aplicación web. La guía contempla pruebas relacionadas con autenticación, autorización, gestión de sesiones, validación de entradas, configuración, lógica de negocio y otras áreas relevantes para Aurora Market. Esto permite realizar una evaluación estructurada y documentar los hallazgos de forma útil para el equipo de desarrollo.

— Fin del Reporte —